

Project: Vulnerability Scanning Using Nessus

Prepared by: Mallikah Sharp

Introduction

Nessus is a powerful and popular vulnerability scanner which uses the vulnerabilities database. It assesses the system for known vulnerable exploits over the given network/IP address.

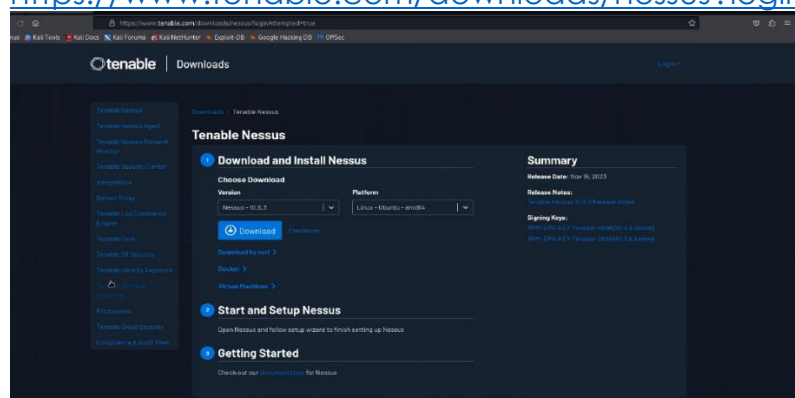
Installing Nessus

First, on the Kali VM update the kali system with latest packages by running the command: “*sudo apt-get update*”

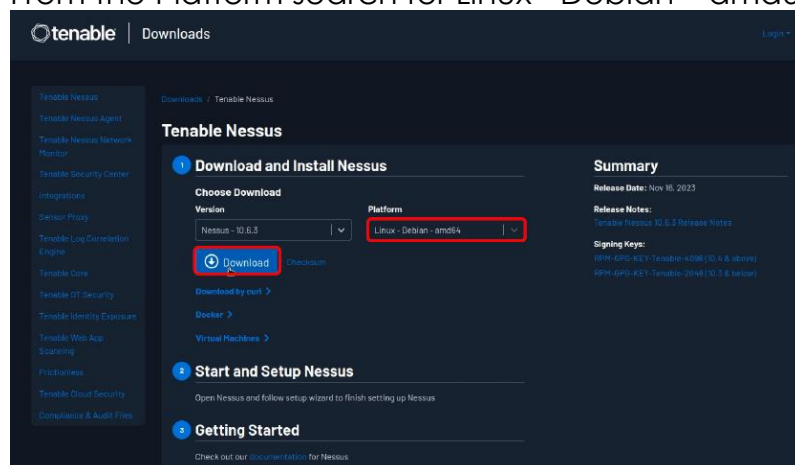
```
(mallikah@Kali)-[~]  
$ sudo apt-get update  
[sudo] password for mallikah:  
Hit:1 http://mirror.ourhost.az/kali kali-rolling InRelease  
Reading package lists... Done
```

Then, go to the website below to install Nessus on Kali Linux:

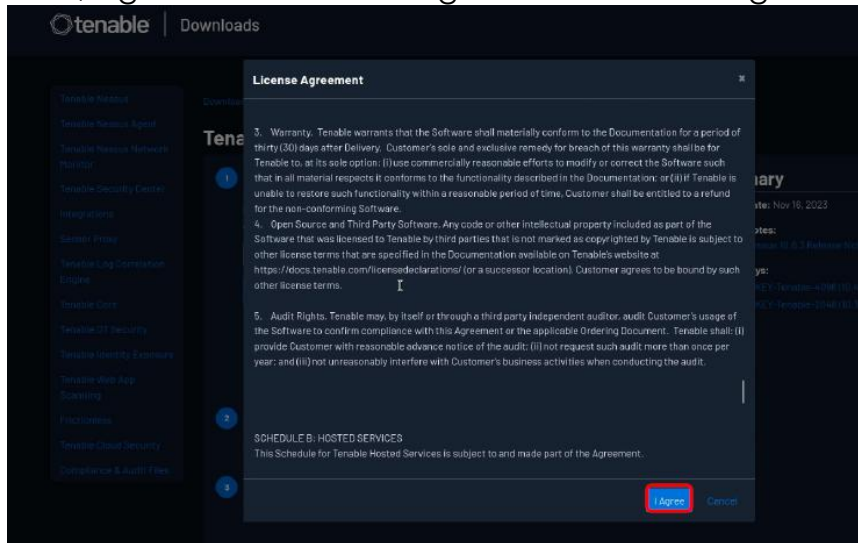
<https://www.tenable.com/downloads/nessus?loginAttempted=true>



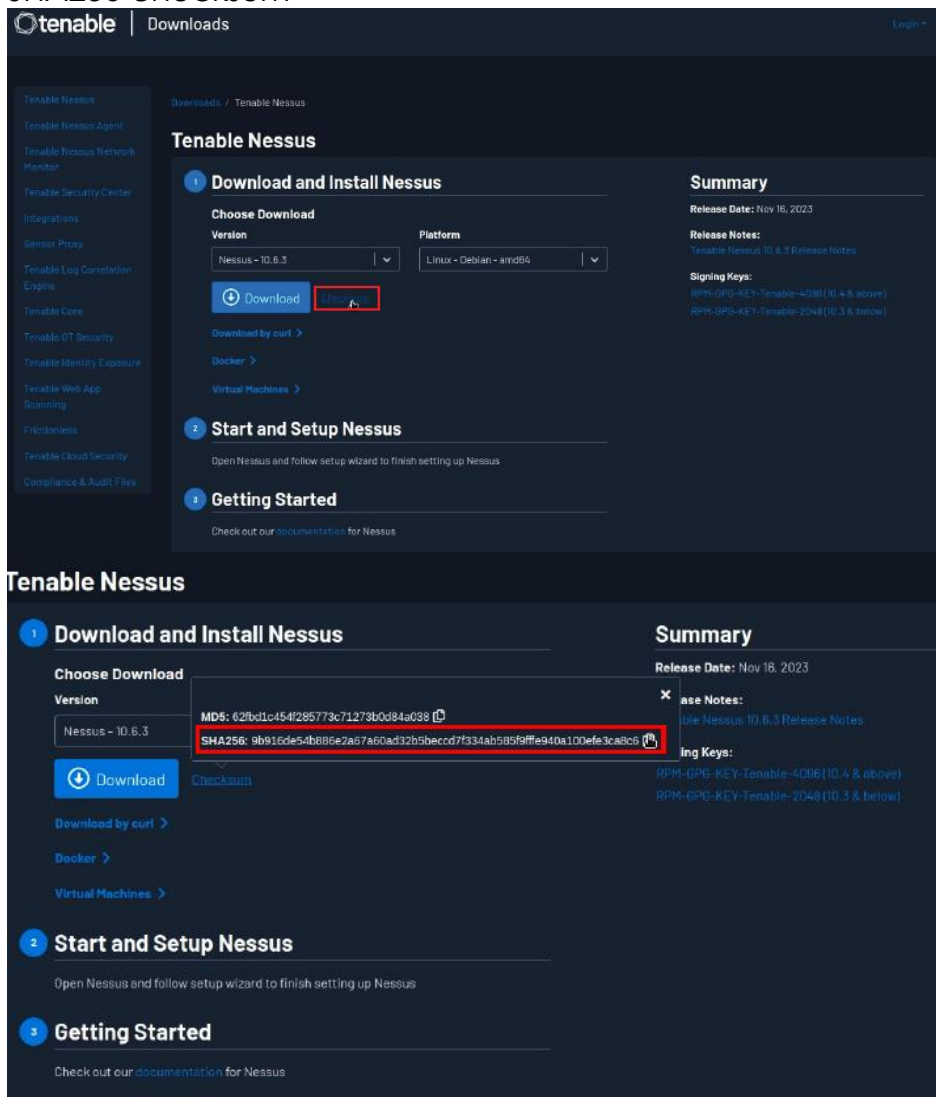
From the Platform search for Linux - Debian – amd64 and download the file.



Next, agree to the license agreement. Click "I agree"



Then, Click on Checksum right next to the download button and copy the SHA256 checksum



Next, Open the ~/Downloads directory in the terminal and enter the following command: `echo`

`"9b916de54b886e2a67a60ad32b5beccd7f334ab585f9fffe940a100efe3ca8c6
Nessus-10.8.3-ubuntu1604_amd64.deb" > sha256sum_nessus`

```
(mallikah@Kali)-[~/Downloads]
$ ls
Nessus-10.8.3-ubuntu1604_amd64.deb  sha256sum_nessus

(mallikah@Kali)-[~/Downloads]
$ echo "9b916de54b886e2a67a60ad32b5beccd7f334ab585f9fffe940a100efe3ca8c6 Nessus-10.8.3-ubuntu1604_amd64.deb" > sha256sum_nessus
```

Run the command: `sha256sum -c sha256sum_nessus`

Install Nessus by running the command:

`sudo apt install ./Nessus-10.8.3-ubuntu1604_amd64.deb`

```
(mallikah@Kali)-[~/Downloads]
$ sudo apt install ./Nessus-10.8.3-ubuntu1604_amd64.deb
Note, selecting 'nessus' instead of './Nessus-10.8.3-ubuntu1604_amd64.deb'
nessus is already the newest version (10.8.3).
The following packages were automatically installed and are no longer required:
 fonts-inter-variable  icu-devtools  libgeos3.13.0  libgtk2.0-common  libpython3.12-minimal  python3.12-tk
 gnome-accessibility-themes  libflac12t64  libglapi-mesa  libicu-dev  libpython3.12-stdlib  ruby-zeitwerk
 gnome-themes-extra  libgail-common  libgtk2.0-0t64  liblbfgsb0  libpython3.12t64
 gnome-themes-extra-data  libgail18t64  libgtk2.0-bin  libpoppler145  python3-setproctitle
Use 'sudo apt autoremove' to remove them.

Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 11
```

Next, you will now need to go to the following website. Fill in your details and click "Get started":

<https://www.tenable.com/tenable-foreducation/nessus-essentials>

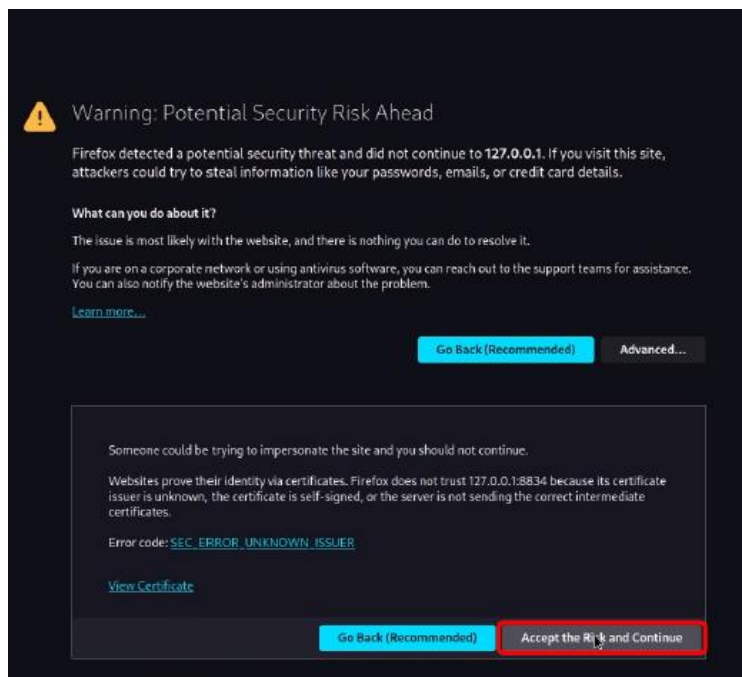
The screenshot shows the 'Nessus for Education' registration page. It includes a header with the Tenable logo and navigation links. The main heading is 'Nessus for Education' with the subtitle 'Tenable Nessus® Essentials Registration Form'. Below this, there is a section titled 'To register to use Nessus Essentials for education, please complete the following form. There is no cost for students and instructors.' followed by instructions for instructors and students. A registration form is displayed on the right, containing fields for 'First Name', 'Last Name', 'Email', and 'Organization'. There is a checkbox for 'Check to receive updates from Tenable' and a 'Get Started' button at the bottom of the form.

Then, open the terminal and run the command:

`sudo systemctl start nessusd.service`

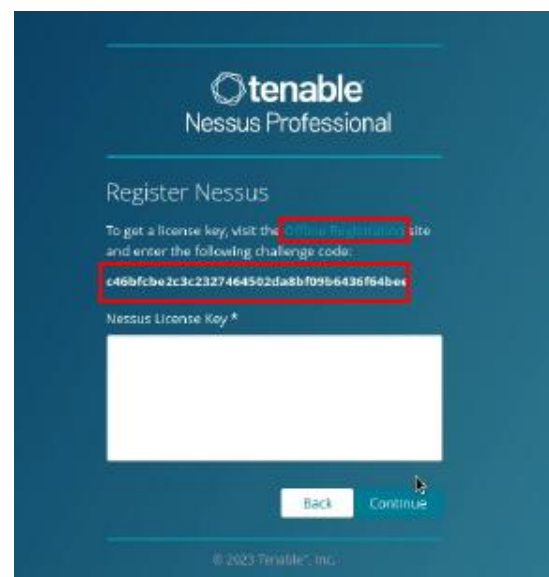
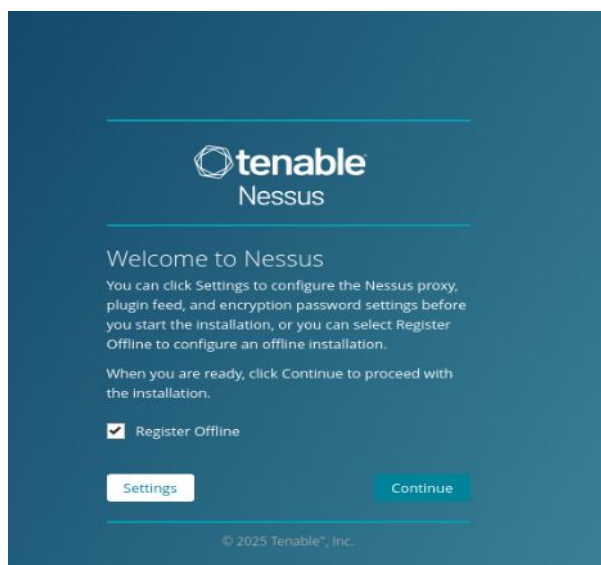
```
(mallikah@Kali)-[~/Downloads]
$ sudo systemctl start nessusd.service
[sudo] password for mallikah:
```

Enter the address <https://127.0.0.1:8834> in your browser. Click on Advanced. Click on Accept Risk and Continue.

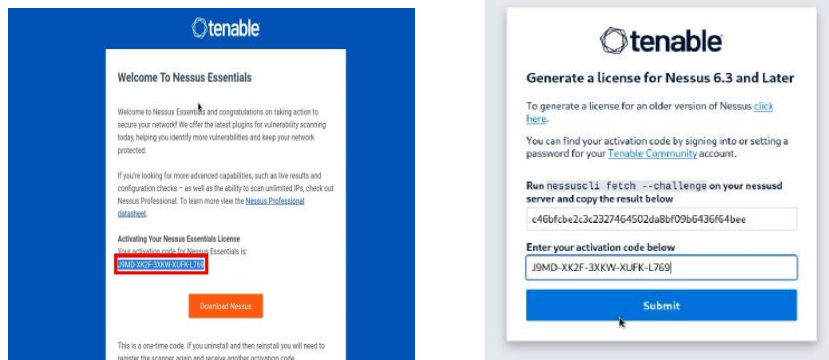


Select Register offline and click continue.

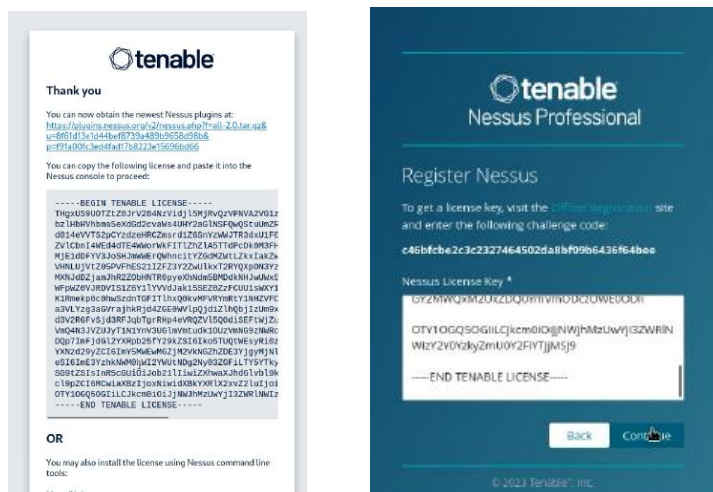
Copy the challenge code and select Offline Registration.



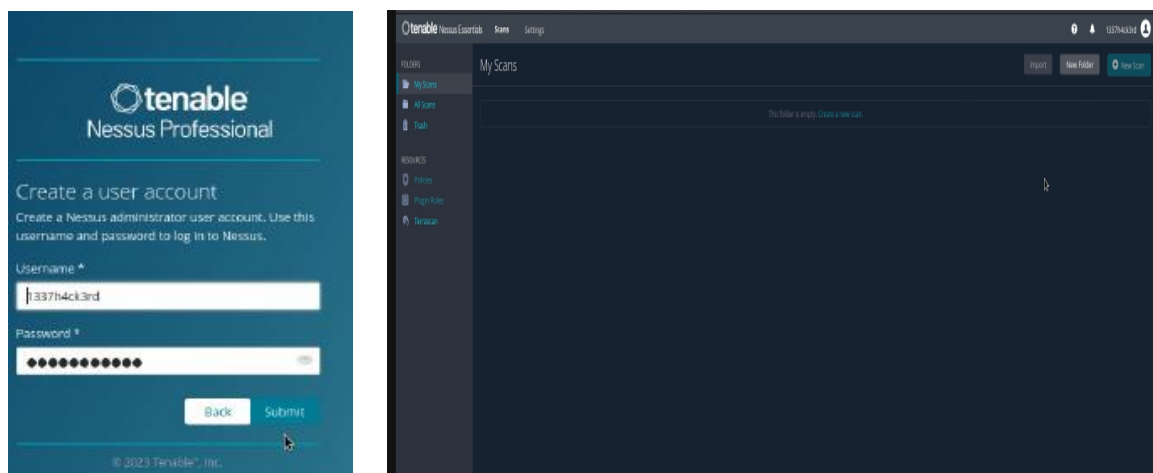
Go to your email and copy the code to Activate Your Nessus Essentials License. Copy your codes into the correct boxes and submit.

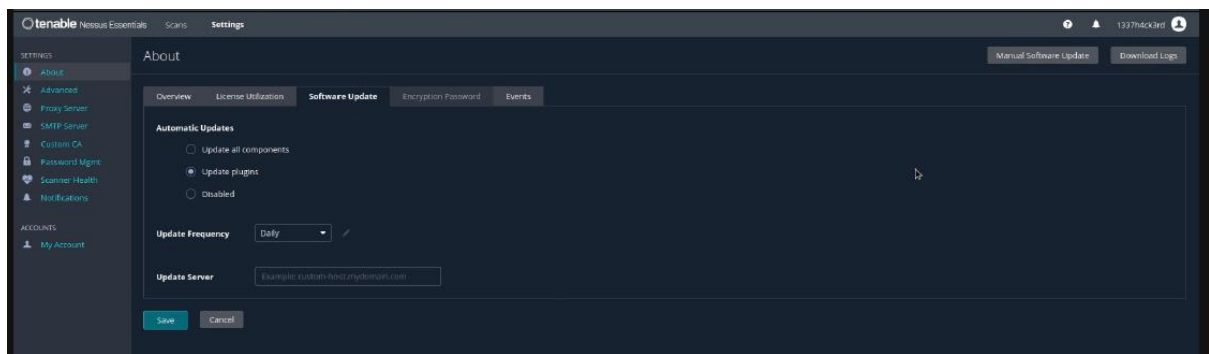


Copy the license code. Paste it under Nessus License key and click continue.

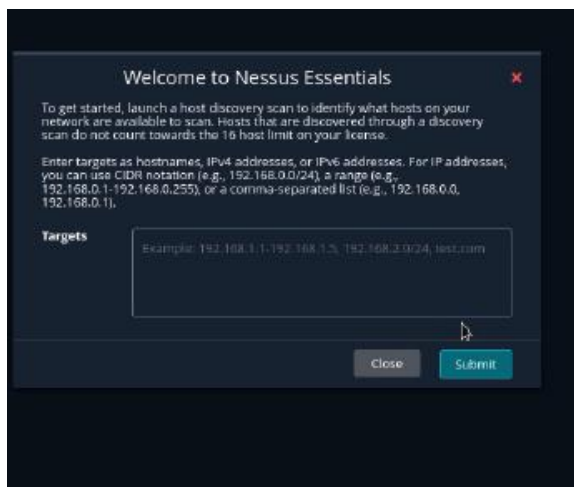


Create your username and password. Nessus has started. Go to settings, select software update.

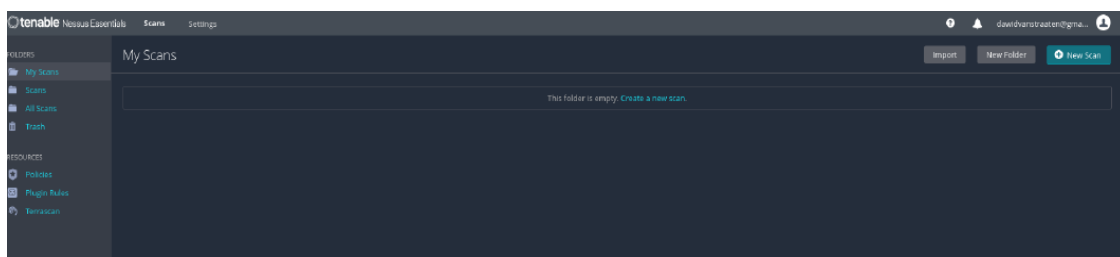




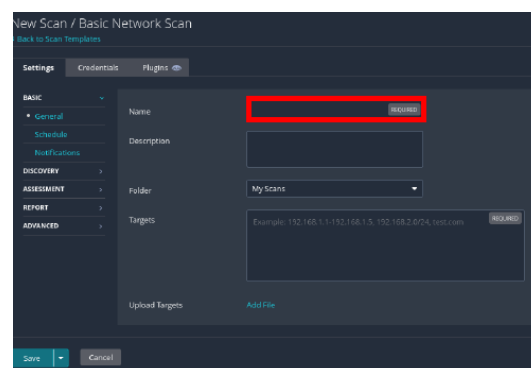
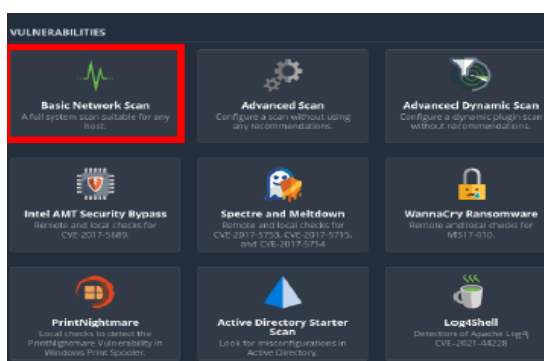
Update all components and paste it under Nessus Essentials License.



We can create a scan by clicking on create a new scan or the new scan button.



Click on basic network scan. Then, enter a name for your scan.



Next, enter the IP address or addresses for your scan.

The left screenshot shows the 'New Scan / Basic Network Scan' interface with the 'Targets' field highlighted by a red box. The text inside the box is 'Example: 192.168.1.1-192.168.1.3, 192.168.2.0/24, 192.168.2.10'. The right screenshot shows the same interface with the 'Targets' field containing the IP address '192.168.0.121'.

There are additional options, you could schedule a scan. And if you have a SMTP server configured, you could get the scan emailed to you.

The left screenshot shows the 'New Scan / Basic Network Scan' interface with the 'Schedule' tab selected. The 'Schedule' toggle switch is set to 'On'. The right screenshot shows the same interface with the 'Emails' tab selected. A message is displayed: 'Notifications will not be sent until your SMTP server is configured.' Below this message is a text input field for 'Email recipient' with the value 'example@rednexus.com'.

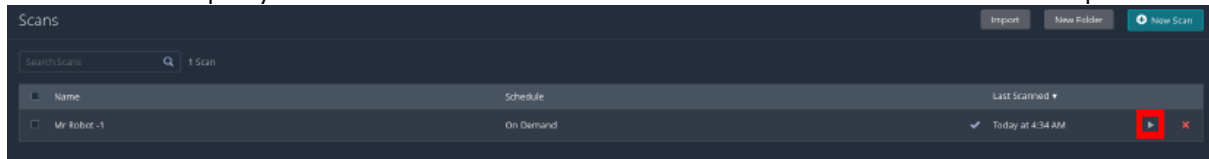
When you click on Discovery, you can see all the different scan types. We're scanning all ports. When you click on Assessment, it will quickly scan for all web vulnerabilities.

The left screenshot shows the 'New Scan / Basic Network Scan' interface with the 'Discovery' tab selected. The 'Scan Type' dropdown is set to 'Port scan (all ports)'. The right screenshot shows the same interface with the 'Assessment' tab selected. The 'Scan Type' dropdown is also set to 'Port scan (all ports)'. Both screenshots show the 'General Settings' and 'Port Scanner Settings' sections.

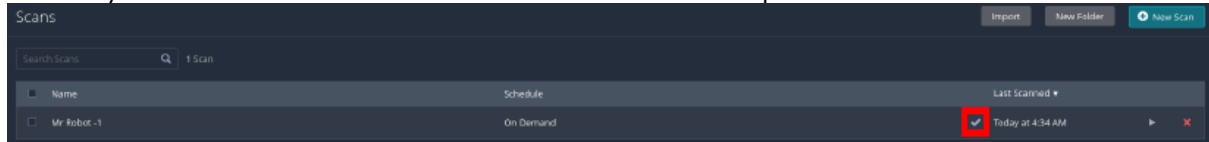
We are not going to make changes to any of the Report settings. On Advanced, you can keep the scan type to default, and click "save".

The left screenshot shows the 'New Scan / Basic Network Scan' interface with the 'Advanced' tab selected. The 'Scan Type' dropdown is set to 'Default'. The right screenshot shows the same interface with the 'Advanced' tab selected. The 'Scan Type' dropdown is also set to 'Default'. The 'Save' button is highlighted with a red box.

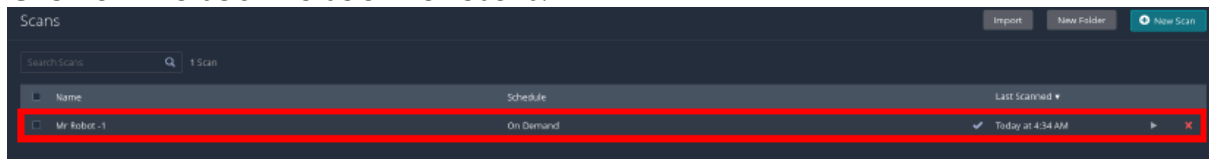
We click the play button to start the scan. We wait until the scan completes.



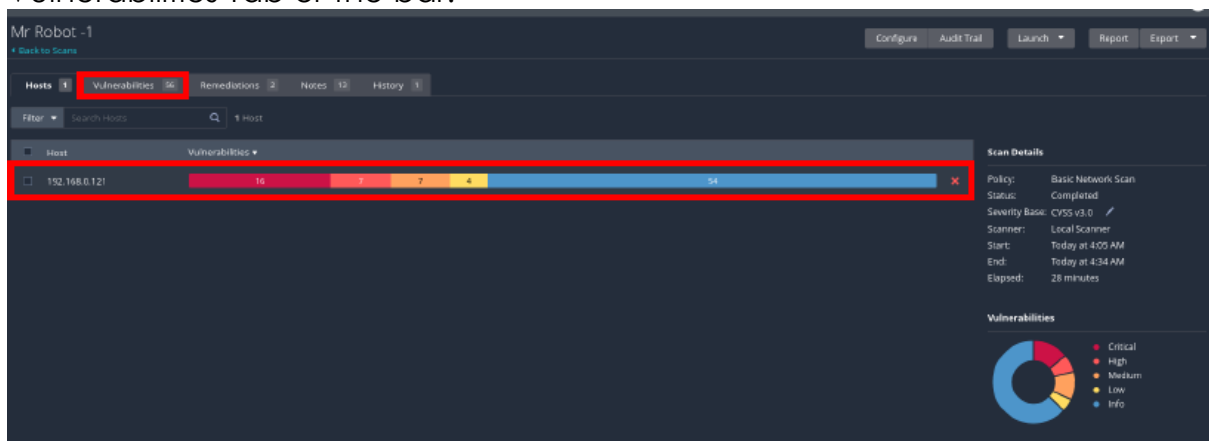
Once you see the “checkmark”, the scan is completed.



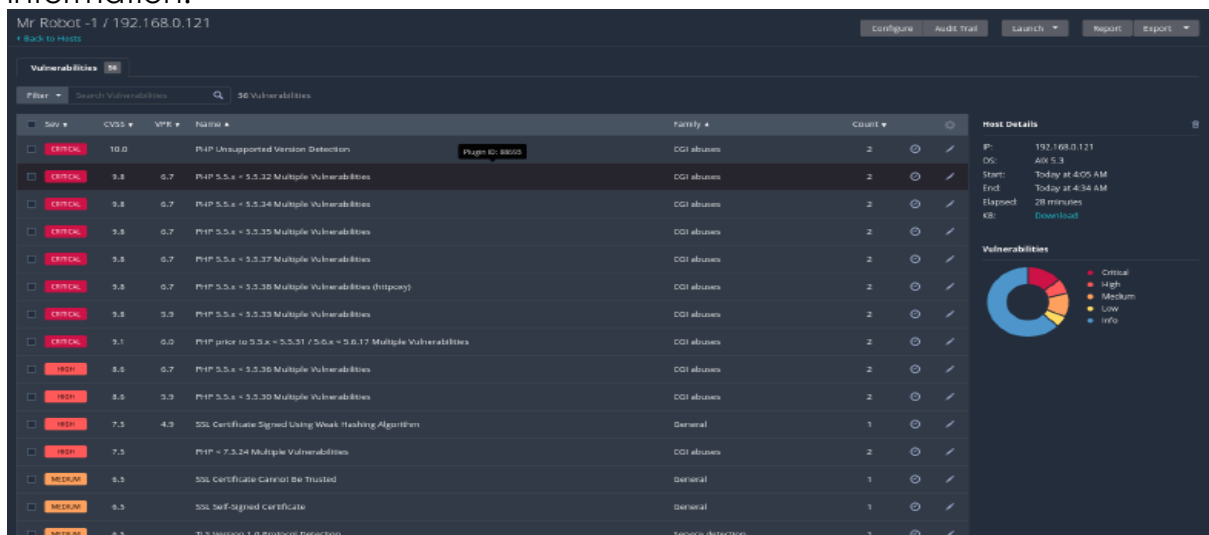
Click on the scan to see the results.



It looks like this machine has quite a few vulnerabilities. We can click on the Vulnerabilities Tab or the bar.



Here we can see all the possible CVEs. We can click on them to get more information.



We will need to do some more research on the CVEs.

The screenshot shows the Nessus web interface for a specific vulnerability. The title is 'PHP Unsupported Version Detection' with a severity of 'CRITICAL'. The description states that the installed version of PHP (5.5.29) is no longer supported, which may lead to security vulnerabilities. The solution is to upgrade to a supported version. The 'Output' section shows the scan results for a host (192.168.0.121) on port 443, indicating that the installed version is 5.5.29 and the end of support date is 2016/07/21. The right sidebar provides additional details, including the CVE ID (CVE-2016-0721), the severity (Critical), and the CVSS v3.0 Base Score (10.0).

Port	Hosts
443 / http / www	192.168.0.121
80 / http / www	192.168.0.121

We can also export the Nessus file with all the CVEs.

The screenshot shows the Nessus web interface with a list of vulnerabilities. The 'Export' button is highlighted in red. The table lists several vulnerabilities, all with a severity of 'CRITICAL'. The vulnerabilities are related to PHP versions 5.5.x and 5.6.x, specifically focusing on unsupported versions and multiple vulnerabilities. The table includes columns for Severity, CVSS, VPR, Name, Family, and Count. The right sidebar shows the scan details, including the policy (Basic Network Scan), status (Completed), severity base (CVSS v3.0), scanner (Local Scanner), start time (Today at 4:05 AM), end time (Today at 4:34 AM), and elapsed time (28 minutes). A donut chart shows the distribution of vulnerabilities by severity: Critical (red), High (orange), Medium (yellow), Low (green), and Info (blue).

Sev	CVSS	VPR	Name	Family	Count
CRITICAL	10.0		PHP Unsupported Version Detection	CGI abuses	2
CRITICAL	9.8	6.7	PHP 5.5.x < 5.5.32 Multiple Vulnerabilities	CGI abuses	2
CRITICAL	9.8	6.7	PHP 5.5.x < 5.5.34 Multiple Vulnerabilities	CGI abuses	2
CRITICAL	9.8	6.7	PHP 5.5.x < 5.5.35 Multiple Vulnerabilities	CGI abuses	2
CRITICAL	9.8	6.7	PHP 5.5.x < 5.5.37 Multiple Vulnerabilities	CGI abuses	2
CRITICAL	9.8	6.7	PHP 5.5.x < 5.5.38 Multiple Vulnerabilities (httpoxy)	CGI abuses	2
CRITICAL	9.8	5.9	PHP 5.5.x < 5.5.33 Multiple Vulnerabilities	CGI abuses	2
CRITICAL	9.1	6.0	PHP prior to 5.5.x < 5.5.31 / 5.6.x < 5.6.17 Multiple Vulnerabilities	CGI abuses	2

Conclusion

This project outlines the installation and utilization of the Nessus tool in Kali Linux, which is used for the vulnerability scanning. While using the Nessus Web interface, users can efficiently create, configure, and run various types of vulnerability scans on a specified IP address or networks. Nessus not only delivers the detailed reports highlighting the vulnerability scans, it also provides their severity along with real time mitigation and recommendations. Nessus is an essential tool for SOC analysts in supporting a proactive threat management and strategizing the security of an organization. Regular scanning, monitoring new vulnerabilities, security misconfigurations, can all help a SOC analyst ensure a more comprehensive approach towards detecting and mitigating security vulnerabilities.